

FIREWALL SECURITY POLICY

Enterprise Multi-Department Network Secured with FortiGate NGFW

VLAN Segmentation • DMZ Isolation • Access Control • NAT Policy

Prepared by: Hamza Ahmed

Track: Network Security – FortiGate Firewall Design

Document Type: Security Policy – Design

September 2026

Contents

Introduction	4
Objectives	4
2 Network Scenario	5
3 Departmental Network Segmentation	6
4 Security Objectives	6
5 Network Components	8
6 VLAN and IP Addressing Plan	9
VLAN Segmentation	9
7 Security Zones.....	9
Security Zone Design	9
WAN Zone	10
Internal Zone	10
DMZ Zone.....	11
8 Firewall Security Policy.....	11
Firewall Policy Objectives.....	11
9 Inter-VLAN Access Control	12
Internal Network Security.....	12
10 DMZ Security Policy.....	13
Internet to DMZ.....	13
Internal to DMZ	14
11 DMZ to Internal	14
12 NAT Policy	15
Source NAT.....	15
13 Destination NAT.....	15
14 Access Control Matrix	16
15 Security Recommendations	16
17 Conclusion	17
18 References	18

List of Figures

Figure 2 Network Diagram	5
--------------------------------	---

List of Tables

Table 1 Departmental Network.....	6
Table 2 Expected Traffic Behavior	7
Table 3 Network Components	8
Table 4 VLAN Segmentation.....	9
Table 5 Security Zones.....	10
Table 6 Outbound Internet Access Policy	12
Table 7 Inter-VLAN Access Control.....	13
Table 8 DMZ Security Policy	14
Table 9 Internal to DMZ	14
Table 10 DMZ to Internal	15
Table 11 Source NAT.....	15
Table 12 Destination NAT	16
Table 13 Access Control Matrix.....	16

Introduction

this document presents a proposed Firewall Security Policy for an enterprise network consisting of multiple departmental VLANs and a dedicated DMZ. The network includes Finance, AI, IT, and Sales departments, in addition to dedicated DNS and Web servers located in the DMZ.

The main purpose of the firewall policy is to control traffic between internal departments, the DMZ, and the Internet while reducing unauthorized access and limiting unnecessary communication between network segments.

The proposed policy follows the principles of network segmentation, least privilege, controlled access, and default-deny security. Each traffic flow is evaluated according to its source, destination, required service, and business purpose.

Objectives

- Control traffic between internal departments.
- Provide controlled Internet access.
- Protect internal networks from unauthorized inbound traffic.
- Isolate public-facing services inside the DMZ.
- Restrict unnecessary inter-VLAN communication.
- Protect the Web and DNS servers.
- Apply NAT for appropriate Internet-bound traffic.
- Provide a clear and manageable firewall rule structure.

2 Network Scenario

Organization Overview

The proposed network scenario represents a small-to-medium enterprise organization with several departments that require secure and controlled access to internal resources and the Internet. The organization consists of four main departments: Finance, AI, IT, and Sales.

To improve network organization and security, each department is assigned to a separate VLAN and IPv4 subnet. This segmentation prevents all users from being placed in a single broadcast and security domain and allows different security policies to be applied to each department.

The network also includes a dedicated Demilitarized Zone (DMZ). The DMZ is used to host servers that provide network services and may require controlled communication with external networks. In this scenario, the DMZ contains a Web Server and a DNS Server.

A FortiGate firewall is positioned between the internal networks, the DMZ, and the external Internet connection. The firewall acts as the main security control point and is responsible for controlling traffic according to defined security policies.

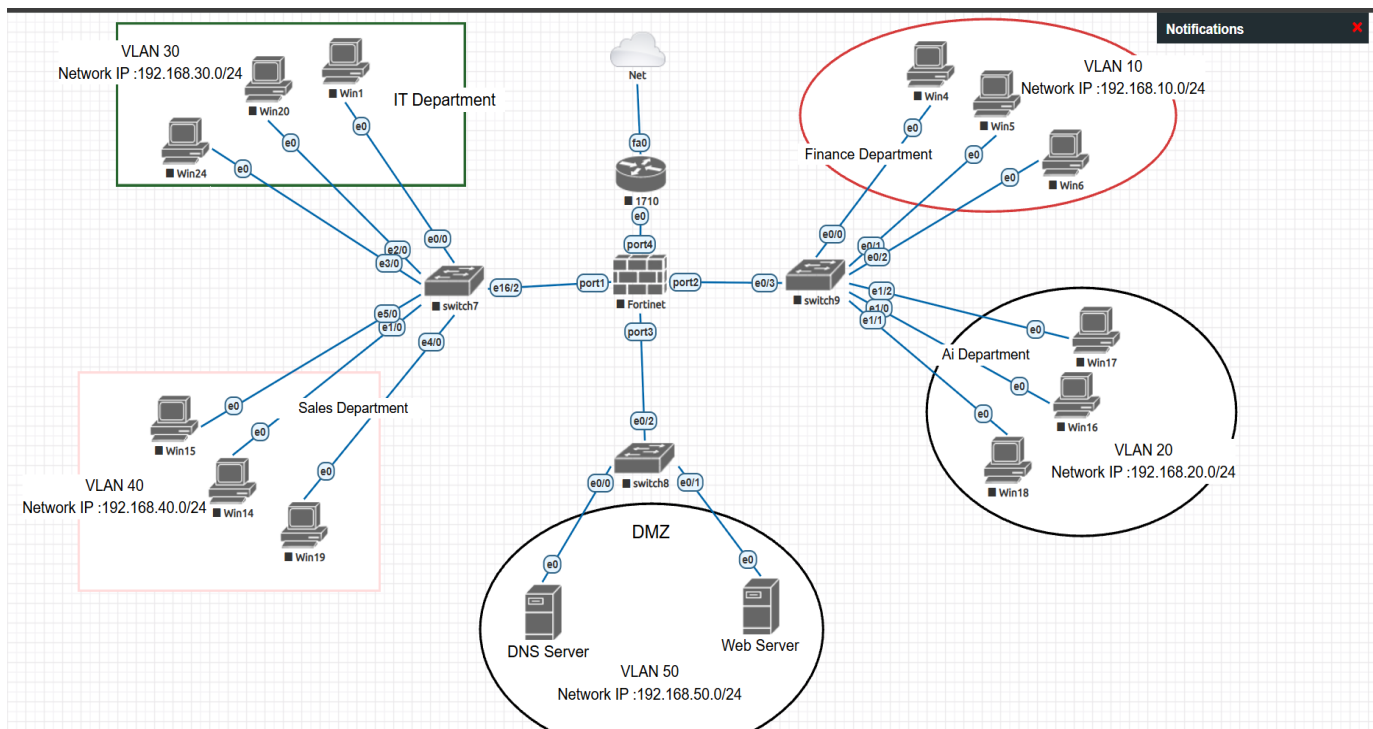


Figure 1 Network Diagram

3 Departmental Network Segmentation

The internal network is divided into four departmental VLANs. Each VLAN has its own IP address range, which provides logical separation between departments.

VLAN	Department	Network Address
VLAN 10	Finance	192.168.10.0/24
VLAN 20	Ai	192.168.20.0/24
VLAN 30	IT	192.168.30.0/24
VLAN 40	Sales	192.168.40.0/24
VLAN 50	DMZ	192.168.50.0/24

Table 1 Departmental Network

Separating the departments into different VLANs allows the firewall to control communication between them. For example, a user in the Sales network should not automatically have unrestricted access to systems in the Finance network.

This approach also helps reduce unnecessary lateral movement if a workstation or user account becomes compromised.

4 Security Objectives

The proposed network architecture has several security objectives.

1. Network Segmentation

Separate each department into its own VLAN and IP subnet.

2. Access Control

Control communication between departments based on actual business requirements.

3. DMZ Isolation

Keep public-facing services separated from internal networks.

4. Internet Protection

Prevent unauthorized inbound Internet traffic from reaching internal systems.

5. Controlled Outbound Access

Allow internal users to access the Internet while applying appropriate NAT and security policies.

6. Least Privilege

Allow only the services and destinations required for legitimate business activities.

7. Limiting Lateral Movement

Prevent unnecessary communication between departments so that a security incident in one network segment does not automatically provide access to other segments.

Expected Traffic Behavior

The expected traffic behavior of the proposed network can be summarized as follows

Traffic Flow	Expected Action	Main Reason
Finance to Internet	Allow	Normal business Internet access
AI to Internet	Allow	Required external access
IT to Internet	Allow	Administrative/technical activities
Sales to Internet	Allow	Normal business Internet access
Internet to DNS server	Allow	Required DNS service
Internet to Web server	Limited Allow	Public web service
Internet to Internal VLANs	Deny	Protect internal systems
DMZ to Internal VLANs	Deny by default	Prevent lateral movement
Finance to Sales	Deny by default	Department isolation
Sales to Finance	Deny by default	Protect sensitive information
AI to Finance	Deny by default	Prevent unnecessary access
IT to Network Resources	Deny by default	Administrative requirements

Table 2 Expected Traffic Behavior

Based on the proposed architecture, the network is divided into multiple security segments with different levels of trust. The internal departmental VLANs are protected from unnecessary lateral communication, while the DMZ provides an isolated environment for services that may require controlled external access. The FortiGate firewall acts as the central enforcement point for these security requirements.

The following sections define the VLAN addressing plan, security zones, firewall policies, NAT requirements, and access-control matrix in greater detail.

5 Network Components

The proposed network consists of several components that work together to provide connectivity, segmentation, and security. Each component has a specific role within the network architecture.

Component	Role
FortiGate Firewall	Provides firewall security, traffic filtering, NAT, and access control
Internal Switches	Connect users and devices within the internal departments
Finance VLAN	Provides network connectivity for Finance users
AI VLAN	Provides network connectivity for AI department users
IT VLAN	Provides network connectivity for IT users and administrators
Sales VLAN	Provides network connectivity for Sales users
DMZ	Isolated network segment for public or controlled-access servers
Web Server	Provides web-based services
DNS Server	Provides DNS/name-resolution services
WAN/Internet	Provides external network connectivity

Table 3 Network Components

Network Traffic Flow

Network traffic is controlled according to its source and destination. Internal users can access the Internet through the FortiGate firewall, where appropriate security policies and NAT rules are applied.

Communication between internal VLANs is not automatically permitted. Instead, access is allowed only when there is a legitimate business or administrative requirement.

External users are not permitted to directly access internal departmental networks. If an external service is required, such as a public web service, access is directed to the appropriate server in the DMZ.

This traffic-flow model reduces unnecessary communication and limits the possibility of unauthorized lateral movement between network segments.

6 VLAN and IP Addressing Plan

VLAN Segmentation

VLAN segmentation is used to divide the enterprise network into separate logical networks. Each department is assigned a dedicated VLAN and IP subnet.

The use of separate VLANs improves network organization and provides a foundation for applying security policies between departments. For example, Finance users can be separated from Sales users, while IT users can be provided with controlled administrative access when required.

The DMZ is assigned a separate VLAN to isolate servers from the internal departmental networks.

Vlan ID	Network Segment	Network Address	Subnet Mask	Default Gateway
Vlan 10	Finance	192.168.10.0/24	255.255.255.0	192.168.10.1
Vlan 20	AI	192.168.20.0/24	255.255.255.0	192.168.20.1
Vlan 30	IT	192.168.30.0/24	255.255.255.0	192.168.30.1
Vlan 40	Sales	192.168.40.0/24	255.255.255.0	192.168.40.1
Vlan 50	DMZ	192.168.50.0/24	255.255.255.0	192.168.50.1

Table 4 VLAN Segmentation

7 Security Zones

Security Zone Design

Security zones are used to group network segments according to their security requirements and trust level. The proposed design contains three primary security zones: WAN, Internal Network, and DMZ.

The WAN represents the external Internet and is considered an untrusted network. Internal networks contain organizational users and therefore require protection from external and unauthorized internal access.

The DMZ represents a separate security zone for servers that may need controlled communication with external networks. Traffic between these zones is controlled by the FortiGate firewall.

Security Zone	Networks	Trust Level	Main Purpose
WAN	Internet	Untrusted	External connectivity
Internal	Vlan 10,20,30,40	Trusted	Department users
DMZ	Vlan 50	Semi-Trusted	Servers and public services

Table 5 Security Zones

WAN Zone

The WAN zone represents the external Internet. Traffic originating from the WAN is considered untrusted and should not be allowed to access internal networks unless an explicitly authorized service is required.

Incoming access from the Internet should therefore be limited to specific services hosted in the DMZ, such as the public Web Server.

Internal Zone

The Internal zone contains the Finance, AI, IT, and Sales networks. These networks contain internal users and business resources.

Communication between internal VLANs should be restricted according to business requirements. Users should not automatically have unrestricted access to other departments.

DMZ Zone

The DMZ is a separate network segment designed to host services that may require controlled external accessibility.

The Web Server and DNS Server are placed in the DMZ. Direct access from the Internet to internal departmental networks is prohibited. Communication between the DMZ and internal networks is also restricted and should only be permitted when required.

8 Firewall Security Policy

Firewall Policy Objectives

The main objective of the firewall security policy is to control network traffic according to security requirements and business needs. The policy follows the principle of least privilege, where only required traffic is permitted.

Traffic is evaluated based on the source, destination, service, and required action. Unnecessary or unauthorized traffic is denied.

The policy also separates internal users from external networks and limits access to servers located in the DMZ.

Rule ID	Source	Destination	Service	Action	NAT	Purpose
-1	Finance VLAN	Internet	HTTP/HTTPS/DNS	ALLOW	Enable	Internet access
-2	AI VLAN	Internet	HTTP/HTTPS/DNS	ALLOW	Enable	Internet access
-3	IT VLAN	Internet	HTTP/HTTPS/DNS	ALLOW	Enable	Internet access

-4	Sales VLAN	Internet	HTTP/HTTPS/DNS	ALLOW	Enable	Internet access
-5	DMZ	Internet	Required Services	ALLOW	Enable	Updates/external services

Table 6 Outbound Internet Access Policy

The outbound rules allow internal users to access required Internet services. Source NAT is applied to private internal addresses when traffic leaves the network toward the Internet.

The services allowed should be limited to those required by the organization. Unnecessary services should not be included in the policy.

9 Inter-VLAN Access Control

Internal Network Security

Although the departmental VLANs belong to the same organization, they should not have unrestricted communication with each other. Segmentation is used to reduce unnecessary lateral communication and protect sensitive departmental resources.

For example, Finance users should not have unrestricted access to the IT or Sales networks. Administrative access may be granted to authorized IT personnel when required.

Source	Destination	Service	Action	Reason
Finance	AI	Any	DENY	Department isolation
Finance	IT	Any	DENY	Protect IT resources
Finance	Sales	Any	DENY	Prevent unnecessary access

AI	Finance	Any	DENY	Protect Finance resources
AI	IT	Any	DENY	Prevent unnecessary access
Sales	Finance	Any	DENY	Protect sensitive resources
Sales	AI	Any	DENY	Department isolation
IT	Internal Networks	Required Management Services	ALLOW	Authorized administration

Table 7 Inter-VLAN Access Control

10 DMZ Security Policy

Internet to DMZ

Internet users may require access to publicly available services. Such access should terminate at the appropriate server within the DMZ rather than directly accessing internal networks.

The Web Server is therefore the primary destination for external HTTP/HTTPS traffic.

Source	Destination	Service	Action	Purpose
Internet	Web Server	HTTP/HTTPS	ALLOW	Public web access

Internet	Internal Networks	Any	DENY	Protect internal network
Internet	Finance	Any	DENY	Protect sensitive data
Internet	IT	Any	DENY	Protect management network
Internet	Sales	Any	DENY	Prevent unauthorized access

Table 8 DMZ Security Policy

Internal to DMZ

Internal users may require access to specific services hosted in the DMZ. Such access should be limited to the required destination and service.

For example, internal clients may be permitted to access the DNS Server for DNS resolution and may access the Web Server using HTTPS when required.

Source	Destination	Service	Action	Purpose
Internal VLANs	DNS Server	DNS	ALLOW	Name resolution
Internal VLANs	Web Server	HTTPS	ALLOW	Web access
Internal VLANs	DMZ	Any Other Service	DENY	Reduce unnecessary access

Table 9 Internal to DMZ

11 DMZ to Internal

Traffic initiated from the DMZ toward internal networks should be highly restricted. DMZ servers should not have unrestricted access to internal departmental networks.

This restriction reduces the potential impact if a public-facing server becomes compromised.

Source	Destination	Service	Action
Web Server	Internal Networks	Any	DENY
DNS Server	Internal Networks	Any	DENY
DMZ	IT	Any	DENY

DMZ	Finance	Any	DENY
------------	----------------	------------	-------------

Table 10 DMZ to Internal

12 NAT Policy

Source NAT

Source Network Address Translation is used when private internal hosts access external networks. The FortiGate translates the private source address into an appropriate external address before forwarding the traffic to the Internet.

This allows multiple internal hosts to share external connectivity while keeping their private addressing scheme internal to the organization.

Rule ID	Source	Destination	NAT	Purpose
NAT-01	Finance	Internet	Source NAT	Internet access
NAT-02	AI	Internet	Source NAT	Internet access
NAT-03	IT	Internet	Source NAT	Internet access
NAT-04	Sales	Internet	Source NAT	Internet access
NAT-05	DMZ	Internet	Source NAT	Required outbound traffic

Table 11 Source NAT

13 Destination NAT

Destination NAT can be used when an external user needs to access a service hosted on a private address inside the DMZ. In this scenario, incoming web traffic can be translated to the private IP address of the Web Server.

Only the required public service should be exposed. Other internal addresses and services should remain inaccessible from the Internet

Rule ID	External Source	Public Service	Internal Destination	Service
DNAT-01	Internet	Public Web IP	192.168.50.10	HTTP/HTTPS

Table 12 Destination NAT

14 Access Control Matrix

The following access-control matrix summarizes the main communication relationships between the proposed security zones.

Source / Destination	Finance	AI	IT	Sales	DMZ	Internet
Finance	ALLOW	DENY	DENY	DENY	LIMITED	ALLOW
AI	DENY	ALLOW	DENY	DENY	LIMITED	ALLOW
IT	LIMITED	LIMITED	ALLOW	LIMITED	ALLOW	ALLOW
Sales	DENY	DENY	DENY	ALLOW	LIMITED	ALLOW
DMZ	DENY	DENY	DENY	DENY	ALLOW	LIMITED
Internet	DENY	DENY	DENY	DENY	LIMITED	—

Table 13 Access Control Matrix

ALLOW indicates that communication is permitted when required. DENY indicates that communication is blocked. LIMITED indicates that only specific services or destinations are permitted according to the firewall policy.

15 Security Recommendations

The proposed firewall architecture provides a basic security foundation, but additional security controls should be considered to improve the overall security posture of the organization.

Least Privilege

Firewall policies should permit only the traffic required for legitimate business operations.

Default Deny

Unmatched and unnecessary traffic should be denied instead of being permitted by broad allow rules.

Network Segmentation

Departmental VLANs should remain logically separated to reduce unnecessary lateral communication.

DMZ Isolation

Public-facing servers should remain isolated from internal networks.

Administrative Access

Administrative access to the FortiGate should be restricted to authorized IT personnel.

Logging and Monitoring

Firewall logs should be enabled and reviewed regularly to identify denied connections, suspicious traffic, and policy violations.

Rule Review

Firewall rules should be reviewed periodically to remove obsolete or unnecessary policies.

Configuration Backup

Regular backups of the firewall configuration should be maintained to support recovery in case of configuration loss or device failure.

17 Conclusion

This document presented a proposed Firewall Security Policy for an enterprise network consisting of multiple departmental VLANs and a dedicated DMZ.

The network was designed using logical segmentation to separate Finance, AI, IT, and Sales departments. A dedicated DMZ was introduced to host the Web Server and DNS Server while keeping these services separated from internal user networks.

The FortiGate firewall acts as the central security control point and is responsible for controlling traffic between the WAN, internal networks, and DMZ. The proposed policies use source, destination, service, and action to define permitted and denied traffic.

NAT is used to provide controlled Internet connectivity for private networks, while destination NAT can be used to publish the required Web Server service to external users.

Overall, the proposed architecture follows the principles of network segmentation, least privilege, controlled access, and default-deny security. These controls provide a structured foundation that can be implemented and further enhanced in a production FortiGate environment.

18 References

- Fortinet. FortiGate Administration Guide – Firewall Policies.
- Fortinet. FortiGate Documentation – Firewall Policy Configuration.
- Fortinet. FortiGate Documentation – NAT and Virtual IP Configuration.
- Fortinet. Fortinet Security Best Practices.